



Test Against Your Real Infrastructure. Break Nothing.

Clone production. Run AI pentests against the clone.
Destroy it when done.

A workflow that removes the production-accuracy vs. production-safety tradeoff every existing tool forces

Rediacc | 2026

The Breach Cost Crisis

14 Days of Visibility a Year



Most organizations run 1 to 2 pentests a year (Core Security/Portra 2024). That delivers under 14 days of security visibility annually. The other 351 days are unknown.

For context: the average data breach cost reached **\$4.88 million in 2024**, the largest year-over-year jump since the pandemic (IBM Cost of a Data Breach 2024).

The diagnostic question: what would your testing cadence look like if running it carried zero production risk?

The AI Pentesting Bounded-Autonomy Problem

97% Would Consider It. Gartner Says Don't Unleash It.

97% of organizations would consider AI penetration testing and **90% believe AI will eventually take over pentesting entirely** (Aikido 2026 State of AI in Security). Autonomous pentest platforms run real attack chains end-to-end: reconnaissance, credential cracking, lateral movement, privilege escalation, exfiltration, without human operators writing scripts.

Gartner's analysis identifies the limits on these platforms: lack of strategic reasoning, fragility in complex environments, inability to test business-logic flaws, LLM hallucinations that invent non-existent vulnerabilities, and the accountability gap when autonomous tooling causes production harm. The near-term consensus is "bounded autonomy", approval-gated actions, strict scope enforcement, operational guardrails, rather than fully unleashed AI agents against live systems.



The shift in framing is this: **the security tooling stops asking for safe production access and gets unsafe clone access instead**. Bounded autonomy is what most teams actually deploy, and it directly degrades testing effectiveness. The same constraints that protect production also block the tool from finding the vulnerabilities a real attacker would. Scope restrictions, approval gates, and "do not exploit" rails were never engineering choices, they were risk management for the target environment.

The target environment is the variable. An identical AI pentest agent run against a disposable clone needs none of those rails, because no consequence can land on production data, production SLAs, or production third-party integrations. The bounded-autonomy compromise dissolves the moment the target stops being production.

Worth asking your team: which of your tools are running degraded today specifically because they would otherwise touch prod?

The Impossible Tradeoff

Production Accuracy vs. Production Safety

Three vendor approaches map the current state of the art, and all three sit on the same tradeoff curve.

Pentera runs "safe by design" real-world attacks directly against production. The platform generates approximately **10,000 alerts per assessment, distilled to 6 to 8 exploitable root causes**. The non-destructive payload claim is real engineering work. Production testing still carries system stress, third-party cost overruns, WAF interference, and data-exposure risk operations teams must coordinate around.

Horizon3.ai NodeZero takes the most aggressive approach: truly autonomous, no predefined playbooks, dynamic discover-and-exploit based on real-time findings. Horizon3 reports **150,000+ autonomous pentests across 3,000+ organizations with zero reported downtime**. Even so, Horizon3 acknowledges the structural problem from the other side: **over 40% of pentest results are invalid by the time they arrive**, because production state changes during the assessment window.

XM Cyber moves to the opposite corner: a "cyber digital twin" that models attack paths mathematically without executing exploits. Production risk drops to zero. Exploitability becomes a model output, carrying the false-positive and false-negative profile of any model that never fires the exploit.

SimSpace marks a third corner that does exist today, but at consulting cost and annual cadence. As US Cyber Command's primary range, SimSpace builds high-fidelity replicas of customer environments with the customer's actual security stack, through extensive professional services. The path is typically used for 1 to 2 annual exercises, not for continuous testing on every infrastructure change.

10,000 alerts to 6 to 8 root causes (Pentera). 40%+ of pentest results invalid by delivery.

The four points define the curve. Existing tooling lets the security team pick which axis to lose on. A different target environment removes the choice.

For your environment: when your last pentest landed, how much of its environment still matched production?

The Production Parity Problem

Misconfiguration Is the #1 Cloud Security Threat

The Cloud Security Alliance's 2024 Top Threats report ranks **misconfiguration as the #1 cloud security threat**, above zero-day attacks. The data supporting that ranking is concrete.

15% of all data breaches had misconfiguration as the initial attack vector in 2024 (IBM Cost of a Data Breach). **23% of cloud security incidents stem from misconfigurations**, and **82% of those misconfigurations are caused by human error** rather than software flaws (SentinelOne).

Azure storage accounts show a **60.75% misconfiguration rate across 504,421 checks** (Trend Micro Cloud Conformity). Cloud misconfiguration exploits rose **47% year-over-year** in 2024 according to IBM X-Force Threat Intelligence Index 2024.

The financial impact is documented at the largest scale. The AT&T breach of 2024, affecting **110 million customers**, traced to a misconfigured Amazon S3 bucket exposed when a development environment was promoted to production without security validation. AT&T established a **\$1.2 billion reserve** for breach-related expenses from a single S3 misconfiguration that staging-environment testing should have caught.

The New Relic staging-environment breach in November 2023 demonstrated the reverse failure mode: staging environments with weaker controls than production become the attacker's entry point themselves. The drift cuts both ways.

Configuration drift between staging and production is structural, not negligent. Emergency break-glass fixes bypass change management. Patching cadences diverge across environments.

Cost-driven resource reductions hollow out staging. One change in production triggers cascading downstream changes that staging never sees.

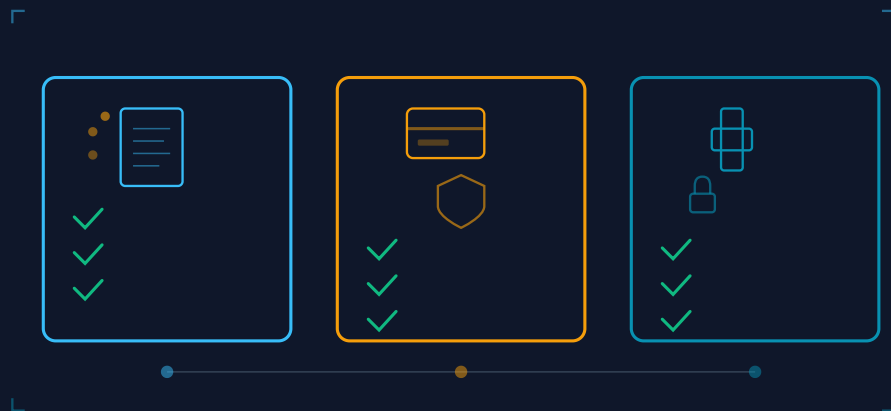
Harness summarized the resulting state: "As you increase the differences between your real-world and test environments, the trust in your staging environment will slowly decline. You will not be able to reliably test in staging because the test results will likely be different in production."

Misconfiguration is the #1 cloud security threat (CSA 2024). 60.75% Azure storage misconfiguration rate (Trend Micro). AT&T set a \$1.2B reserve from one S3 bucket. Staging breaches happen because staging is the weaker target (New Relic, 2023).

The diagnostic question: how recently was your staging environment provably identical to production, and what evidence would you show an auditor?

Compliance Mandates Are Accelerating

DORA, PCI DSS 4.0, HIPAA, and the Continuous-Compliance Floor



The regulatory trajectory is unambiguous: more frequent testing, more realistic targets, more continuous validation.

DORA became effective **January 17, 2025** and applies to **22,000+ EU financial entities**. It requires Threat-Led Penetration Testing at least every three years for systemically important institutions.

DORA explicitly mandates testing on live production systems for TLPT. Penalties reach **1% of average daily worldwide turnover** for up to six months. DORA's broader requirements for general penetration testing can be satisfied with production-clone approaches; the TLPT requirement is the live-production exception.

PCI DSS 4.0 new requirements became mandatory **March 31, 2025**, with annual pentests, quarterly vulnerability scans, and testing after any significant change. The model moves from checkbox controls to outcome-based proof that controls work.

Penalties from payment processors run **\$5,000 to \$100,000 per month**. **Only 14.3% of organizations achieved full PCI DSS compliance in 2023**, down from 43.4% in 2020 (Verizon 2024 Payment Security Report).

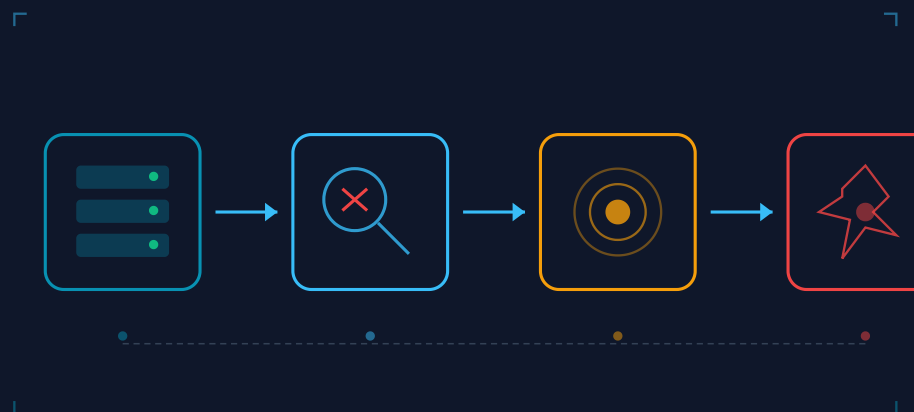
The 2025 proposed HIPAA Security Rule would codify **annual mandatory penetration testing** and semi-annual vulnerability scanning for the first time, removing the "addressable" distinction that previously allowed organizations to skip. Penalties run **\$100 per violation to \$2 million annually** for willful neglect.

Enforcement is real. Albany ENT settled for \$500,000 (HHS OCR, 2024). Enzo Biochem settled for \$4.5 million across state AGs. St. Margaret's Health closed permanently after a ransomware breach. The pattern is enforcement matching the rule, not waiting for the next rulemaking cycle.

Beyond the three headline mandates, SOC 2, ISO 27001, NIST CSF, and the SEC disclosure rules all require security testing evidence. **34% of organizations have lost business due to missing certifications** (A-Lign 2024). **47% failed a formal audit 2 to 5 times in the past three years** (Coolfire 2024).

Clone, Test, Find, Destroy

The Four-Step Workflow and What Each Step Produces



The security tooling stops asking for safe production access and gets unsafe clone access instead. The workflow has four steps. Each step has specific work the security team does on it, and each step produces a specific artifact the next step or the auditor consumes.

Step 1: Clone. REDIACC's btrfs snapshot creates a point-in-time, bit-for-bit identical clone of production infrastructure. No data movement, no rehydration, instantaneous regardless of data volume because the snapshot is a metadata operation. The clone is filesystem-isolated from production with its own network namespace. The security team starts with a target that is provably the same as production at the snapshot timestamp.

Artifact: snapshot manifest (timestamp, source repo, included subvolumes, content hash) that an auditor can match against a production-state record.

Forks start with no secrets. btrfs CoW guarantees storage isolation. Rediacc adds a complementary mechanism at the secrets layer: a fork inherits no environment variables or secret files from its parent. The parent's `rdc repo secret list` shows the Stripe key, SES token, and webhook secret; the fork's list returns nothing. Containers in the fork cannot interpolate `${REDIACC_SECRET_STRIPE_KEY}` because the variable is unset; the file at `/var/run/rediacc/secrets/<fork-id>/STRIPE_KEY` does not exist. An AI pentest agent triggering an exfiltration path against the fork cannot land a real charge or send a real email, because the credentials required to authenticate are absent. A buyer scoping a pentest run sets sandbox credentials explicitly per fork (`rdc repo secret set --name my-app:test --key STRIPE_KEY --value sk_sandbox_xxx --mode file --current ""`) before running the exercise.

Step 2: Test. The security team runs the same tooling already in use, AI pentest agents, exploit chains, chaos experiments, fuzzers, custom red-team scripts, against the clone with all guardrails removed. No scope restrictions, no approval gates, no bounded-autonomy rails.

Destructive techniques that get vetoed against production, data-exfiltration attempts, privilege-escalation chains, lateral movement across the full attack surface, fire freely because the consequences land on a disposable target.

Artifact: exploit traces, tool logs, and full command-history per assessment, exportable for the SOC and for evidence.

Step 3: Find. The security team triages the test output against the production-identical target. Because the clone matches production at the snapshot timestamp, every finding maps to a real production vulnerability.

No false negatives from environment mismatch, no false positives from synthetic configurations. Pentera's 10,000-alerts-to-6-to-8-root-causes pattern still applies; the root causes are now provably exploitable on the production state the clone captured.

Artifact: remediation tickets with the production resource ID, the exploit trace that proved it, and the snapshot timestamp the trace was generated against.

Step 4: Destroy. The clone is destroyed when the assessment closes. No persistent test environment to harden, no residual data exposure surface, no ongoing storage or compute spend.

The next test cycle starts with a fresh clone reflecting current production state, so every assessment captures the latest configurations, patches, and infrastructure changes since the last run.

Artifact: destruction log linked to the snapshot manifest, closing the audit chain from clone creation through findings to teardown.

The bounded-autonomy compromise, the staging-drift validity problem, and the production SLA conflict resolve at the same point, by moving the target.

Worth asking your team: which of your tools, today, would you run in unbounded mode if the target were disposable, and what would change in your finding rate?

Test Against Your Real Infrastructure. Break Nothing.

Clone production, run AI pentests against the clone, destroy it when done. Production parity, zero production risk, evidence the auditor can read.

The bounded-autonomy compromise dissolves when the target stops being production.

Request a Demo | Schedule a Security Assessment | Download the Technical Brief

rediaccc.com

Production-real. Production-safe.